

UNIT VI: MALICIOUS SOFTWARE AND INTRUSION (4 HRS)

6.1. Malicious Software

6.2. Virus and its phases, Virus Classification

6.3. Worm, Worm Propagation Model, State of Worm Technology

6.4. Trojan Horse

6.5. Intrusion and Intruders

6.6. Intrusion Detection System

6.7. Analysis Approaches: Anomaly Based, Signature Based

6.8. Honeypots

MALICIOUS SOFTWARE

- **Malicious software**, or **malware**, is any program designed to harm a computer.
- It is used to break systems, steal private info, or get into private files. Malware includes things like viruses, worms, and Trojans.
- These programs can take control of your computer. They might delete your files or add software you didn't ask for.
- Often, malware starts because a user clicks on a bad email attachment or a fake pop-up on a website.
- Malware is understood using **two key aspects**:
 - i. **Propagation Mechanism** → *How the malware spreads*
 - ii. **Payload** → *What the malware does after infection*
- Modern malware often combines both. This is called a **blended attack**.

A. PROPAGATION MECHANISM (HOW MALWARE SPREADS)

Virus: A virus attaches itself to a legitimate file or program and spreads when that infected file is executed.

- Requires **user action** (running a file, opening a document).
- Infects other executable files.
- Cannot spread on its own.

Worm: A worm is a standalone program that spreads automatically across networks.

- Exploits software vulnerabilities.
- Does **not** need a host file.
- Spreads without user action.
- Examples: **Melissa worm, Code Red, Stuxnet,**

Trojan Horse: A Trojan disguises itself as useful software but performs hidden malicious actions.

- Does **not** replicate itself.
- Tricks users into installing it.
- Often used to deliver other malware like ransomware or spyware.

B. PAYLOAD (WHAT MALWARE DOES AFTER INFECTION)

a. System Corruption

- Deletes or modifies system files.
- Crashes the operating system.
- Damages data and applications.

b. Botnets

- Infected computers become part of a remote-controlled network (botnet).
- Used to perform:
 - i. DDoS attacks
 - ii. Spam sending
 - iii. Cryptocurrency mining

c. Phishing

- Steals user credentials by showing fake login pages.
- Captures passwords, banking details, OTPs.

d. Spyware

- Secretly monitors user activity.
- Records keystrokes (keylogging).
- Captures screenshots and browsing habits.

e. Rootkits

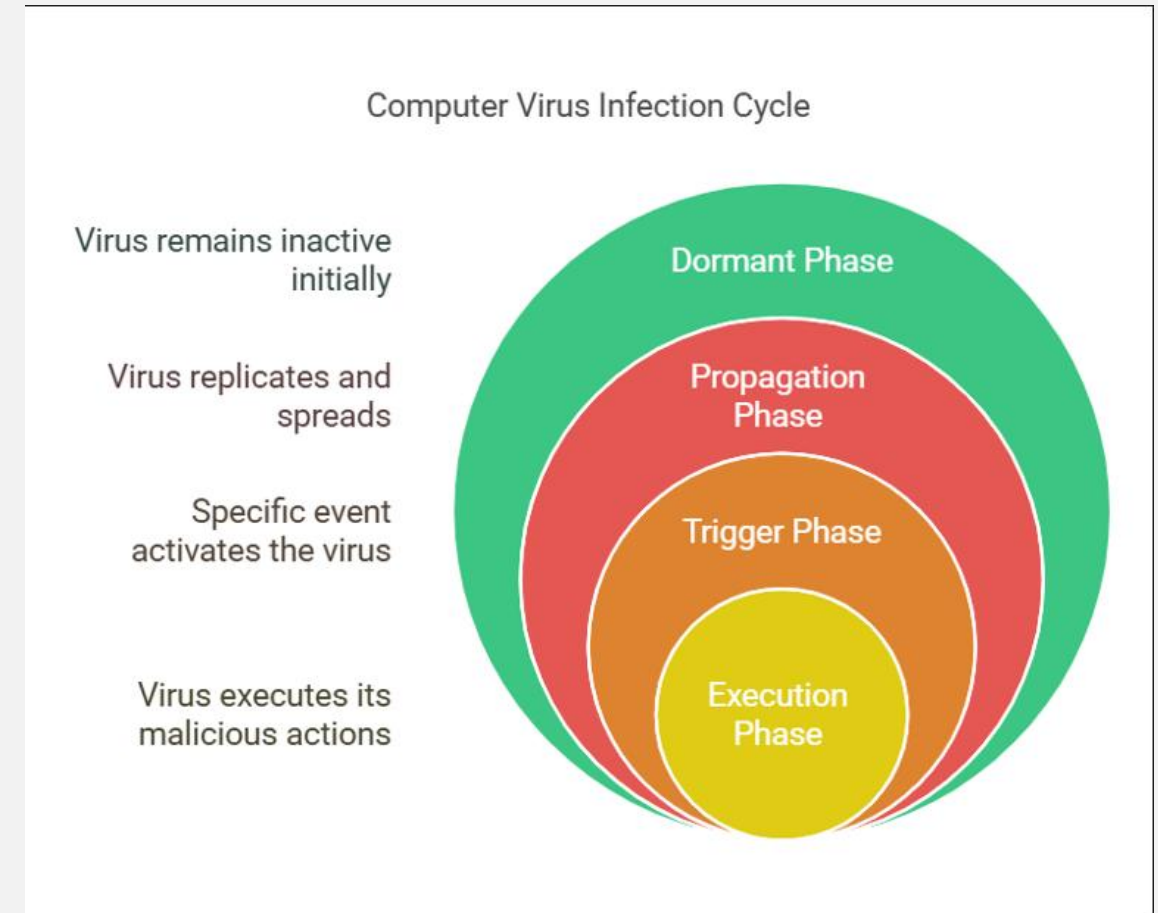
- Hides malware deep inside the operating system.
- Prevents detection by antivirus software.
- Gives attackers long-term hidden access.

COMPUTER VIRUS

- A **computer virus** is a **malicious software program** designed to **infect a computer, replicate itself, and spread to other files, programs, or devices**—much like a biological virus spreads between living organisms.
- When the infected program runs, the virus activates, causing harmful actions such as deleting data, slowing down systems, corrupting files, or giving unauthorized access to hackers.
 - **Key Characteristics**
 - **Self-replicating:** Copies itself into other files or systems.
 - **Requires a host:** Usually attaches to programs, documents, or boot sectors.
 - **Activates when triggered:** Runs when the infected program is opened.
 - **Spreads across systems:** Through USB drives, email attachments, downloads, networks, etc.

FOUR PHASES OF A VIRUS

1. **Dormant Phase** – Waits for a condition (date/event).
2. **Propagation Phase** – Infects other files and spreads.
3. **Triggering Phase** – Activated by a specific event.
4. **Execution Phase** – Payload is executed.



VIRUS CLASSIFICATION

1. By Target

- **Boot Sector Infector:** Infects the master boot record and activates when the system starts.
- **File Infector:** Attaches to executable program files and spreads when they run.
- **Macro Virus:** Infects documents using application macros or scripts (e.g., Word/PDF).

2. By Concealment

- **Encrypted Virus:** Encrypts its code to hide its signature from antivirus detection.
- **Stealth Virus:** Hides its presence by manipulating system functions to avoid detection.
- **Polymorphic Virus:** Changes its code pattern with each copy to evade signature scanners.
- **Metamorphic Virus:** Completely rewrites its own code each time to appear entirely different.

2. WORM

- A **worm** is a type of **malware** that can **self-replicate and spread independently** across computers and networks without needing a host file or human intervention.
- **Key Points about Worms:**
- **Self-replicating:** Can copy itself to other systems automatically.
- **No host required:** Unlike viruses, worms are standalone programs.
- **Spreads through networks:** Often via email, network shares, or internet vulnerabilities.
- **Effects:** Can slow down networks, delete files, crash systems, or create backdoors for hackers.
- **Examples:** Code Red, Conficker, ILOVEYOU (worm variant).

HOW WORMS PROPAGATE (WORM PROPAGATION MODEL)

Worms spread by finding weaknesses in operating systems, applications, or network services.

1) Network Connections

- The worm scans IP addresses on a local network or the internet.
- It looks for systems with known security vulnerabilities (e.g., unpatched servers).
- Once found, it automatically transfers and executes itself on the target machine.

2) Shared Media

- Worm copies itself to USB drives, CDs, or shared folders.
- When the device is connected to another computer, the worm executes and spreads.

3) E-mail

- Worm sends itself as an attachment or link using the victim's email contacts.
- The attachment often contains macro/script code that runs when opened.

STATE OF WORM TECHNOLOGY (EVOLUTION OF WORMS)

a) Speed of Contagion

- **Melissa worm** infected ~100,000 computers in 3 days via email macros.
- **Code Red** infected ~360,000 servers in 14 hours by exploiting a web server flaw.
- These showed how worms could cause **global damage in hours**.

b) Advanced Targeting

- **Stuxnet** was highly specialized.
- Targeted industrial control/SCADA systems used in nuclear facilities.
- Used multiple **zero-day vulnerabilities** (unknown flaws).
- Designed to remain hidden while damaging physical equipment.

c) Mobile Platforms

- Modern worms target smartphones.
- Spread through: Bluetooth connections , MMS messages, Malicious apps
- Affects both Android and iOS environments when vulnerabilities exist.

3. TROJAN HORSE

- A **Trojan Horse** (or **Trojan**) is a type of **malware** that **disguises itself as a legitimate or useful program** to trick users into installing it.
- **Key Points about Trojans:**
- **Disguised as legitimate software:** Appears harmless, like a game, utility, or document.
- **Does not self-replicate:** Unlike viruses or worms, it cannot spread on its own.
- **Used for malicious purposes:** Steals data, installs backdoors, gives remote access to attackers, or downloads other malware.
- **Effects:** Data theft, system compromise, unauthorized access.
- **Examples:** Zeus, Emotet, FakeAV.

TROJAN HORSES

- A **Trojan** looks like a helpful or fun program, but it is actually hiding something bad inside.
- **The Trick:** You might download a game, but once you open it, the Trojan lets a hacker into your computer.
- **Difference:** Unlike worms, Trojans do not copy themselves or spread on their own.

Feature	Virus	Worm	Trojan Horse
Basic idea	Parasitic code that attaches to files	Standalone program that self-spreads	Malicious program disguised as useful software
Needs host file	Yes	No	No
Needs user action to spread	Yes (run infected file)	No	Yes (user installs/runs it)
Self-replication	Yes	Yes	No
Main purpose	Infect files and spread	Spread rapidly across networks	Deliver hidden malicious actions (payload)
Spreads through	Infected executables/documents	Network scanning, email, USB	Downloads, fake apps, attachments
Speed of spread	Slow to moderate	Very fast	Does not spread by itself
Typical damage	File corruption, data damage	Network overload, large-scale infection	Data theft, backdoor, ransomware/spyware delivery
Example	Boot/file/macro infectors	Code Red	Fake antivirus, cracked software installers

INTRUSION AND INTRUDERS

Intrusion

- An **intrusion** is any set of actions that attempts to **compromise the confidentiality, integrity, or availability (CIA)** of a computer system or network resource.

Intruders

- **Intruders** are individuals who attempt to gain **unauthorized access** to a system or who **misuse authorized access**.

Type	Definition
Masquerader	An unauthorized person who gains access by pretending to be a legitimate user.
Misfeasor	A legitimate user who misuses their access privileges.
Clandestine User	A person who gains supervisory control and hides their activities from auditing and security controls.

INTRUSION DETECTION SYSTEM (IDS)

- An **Intrusion Detection System (IDS)** is a security tool that **monitors network or system activities to detect suspicious or malicious behavior.**
- It helps identify **unauthorized access, attacks, or policy violations** in a computer system or network.

Main Functions

- Monitor network traffic and system activities
- Detect possible security threats or attacks
- Generate alerts to administrators
- Record events for security analysis

TYPES OF INTRUSION DETECTION SYSTEMS

1. Network-Based IDS (NIDS)

- A **Network-Based IDS** monitors and analyzes **network traffic flowing across the entire network**.
- It is usually placed at important points in the network such as **routers, switches, or gateways** to observe incoming and outgoing packets.
- It detects suspicious packets or abnormal network behavior.

2. Host-Based IDS (HIDS)

- A **Host-Based IDS** is installed on **individual computers, servers, or devices**.
- It **monitors activities** within the system such as: **File changes, System logs, Running processes, User activities**
- It protects only the device where it is installed.

DETECTION METHODS

1. Signature-Based Detection

- This method identifies attacks by **comparing system activity with a database of known attack signatures (patterns)**.
- A signature is a **specific pattern that indicates a known attack**.
- **Example:** If the IDS detects a network packet pattern that matches a **known malware attack**, it triggers an alert.

2. Anomaly-Based Detection

- This method detects attacks by identifying **unusual behavior that deviates from normal system activity**.
- The IDS first learns what **normal network or system behavior looks like**, then it flags activities that are significantly different.
- **Example:** If a user normally logs in once a day but suddenly tries **100 login attempts in one minute**, the IDS detects it as suspicious.

HONEYPOT

- A **honeypot** is a **security resource** which is typically a *decoy system* designed to be probed, attacked, or compromised.
- It is used as a **perimeter scanning approach** to capture incoming malware traffic and gather intelligence on attacker methods.

Purpose and Utility

Honeypots serve several key functions in a security strategy:

- **Malware Capture:** They can capture incoming malware traffic to assist in identifying new threats.
- **Attack Detection:** They can house monitoring software (such as **ingress or egress monitors**) to catch the source of a malware attack by watching for scanning or other suspicious behavior.
- **Intelligence Gathering:** By observing how an attacker interacts with the decoy, security professionals can identify the tools and vulnerabilities being exploited.

ROLE IN MALWARE COUNTERMEASURES

Honeypots are often integrated into broader defense systems:

- **Ingress Monitoring:** They can be placed at the border of an enterprise network to monitor traffic to unused local IP addresses.
- **Egress Monitoring:** They can be used to detect the source of an internal attack by monitoring outgoing traffic for signs of worm scanning or abnormally high e-mail volume.
- **Botnet Defense:** They assist in detecting and responding to botnet activity by identifying abnormal traffic patterns, particularly during the botnet's construction phase.



- End of Unit 6